

目录

第 1 章 路由协议安全	1
引言	1
1.1 针对域内路由协议 OSPF 的攻击和防御	2
1.1.1 OSPF 协议基础知识	2
1.1.2 OSPF 协议安全威胁分析	4
1.1.3 针对 OSPF 协议安全漏洞的攻击	7
1.1.4 OSPF 协议安全增强方案	10
1.2 针对域间路由协议 BGP 的攻击和防御	13
1.2.1 BGP 协议基础知识	13
1.2.2 BGP 协议面临的典型安全威胁	15
1.2.3 虚假路由宣告检测	17
1.2.4 路由协议安全性增强	21
1.2.5 前沿研究进展	28
总结	32
习题	37

1

路由协议安全

引言

互联网路由协议安全是保障网络空间安全的重要基础。在一个正常的路由系统中，路由器通过路由协议交换互联网中的路由信息，并计算到达目的端的最优路径。然而，当今互联网中广泛使用的路由协议，如 OSPF、BGP 等，本身存在诸多设计缺陷和实现漏洞，易遭受各类攻击。路由协议的正常运行如果遭到破坏，就会导致路由器获取的路由信息错误，进而造成流量转发错误，目的端不可达。针对路由协议的攻击还可以作为其他网络攻击的基础，如监听流量、发送垃圾邮件、窃取数字货币等，严重危害互联网上层应用的稳定运行和数据安全。

本章将介绍互联网域内和域间路由协议面临的各类安全威胁及防护方案。具体地，第1.1节将介绍域内路由协议 OSPF 自身的漏洞、针对 OSPF 的典型攻击方式和相应防御技术。在第1.2节中，将介绍域间路由协议 BGP 存在的安全问题、针对 BGP 协议的攻击检测方案和 BGP 安全增强方案。互联网域内域间路由架构介绍及配图

对路由算法不太了解的读者，可以参考《高级计算机网络（第2版）》中的相关介绍。

1.1 针对域内路由协议 OSPF 的攻击和防御

OSPF 是当前最为广泛使用的域内路由协议，具有部署便捷、收敛的优点。然而，OSPF 协议存在诸多设计和实现上的安全漏洞，攻击者可以利用它们对域内网络的路由器进行攻击，以实现干扰域内网络正常通信的不法目的。本节将具体介绍 OSPF 协议的基础知识、OSPF 协议存在的安全隐患、攻击者针对 OSPF 协议的典型攻击方式和 OSPF 协议的安全增强方案。

1.1.1 OSPF 协议基础知识

IPv4 网络使用 OSPFv2 协议 (RFC2328^[1])，而 IPv6 网络使用 OSPFv3 协议 (RFC2740^[2])。

IS-IS 介绍

OSPF 协议的全称是开放最短路径优先协议 (Open Shortest Path First)，其由 IETF 在 IS-IS 协议的基础上开发，用于解决早期开发的路由信息协议 RIP 的一系列固有缺陷：(1) 基于距离向量工作且具有跳数的限制；(2) 不支持可变长子网掩码导致 IP 地址分配低效率；(3) 需要周期性广播整个路由表而不适用于低速率链路和广域网；(4) 收敛速度低且对拓扑变化反应较为迟钝。与 RIP 协议不同，OSPF 是一种基于链路状态的路由协议，运行 OSPF 的路由器会先收集链路状态信息，再根据 Dijkstra 最短路径算法计算出自己到每台路由器的最短路径来作为路由。并且，OSPF 协议完全支持无类别域间路由 (Classless Inter-Domain Routing: CIDR) 功能，可以对 IP 目的地址进行完全无类别地处理。从整体上看，OSPF 协议的工作过程主要分为以下几步：(1) 运行 OSPF 协议的路由器发送 Hello 报文，找到同样运行 OSPF 协议的其他路由器并建立紧邻 (Adjacency) 关系；(2) 建立了紧邻关系的 OSPF 路由器之间通过链路状态通告 (Link-State Advertisement: LSA) 来交换路由器的链路状态信息；(3) 计算出最短的路由路径并生成路由表。本节接下来将具体介绍 OSPF 的这三个主要工作过程。加一张图

代表路由器、备份代表路由器？

- **建立紧邻关系。** OSPF 路由器之间建立紧邻关系主要通过以下两个步骤：发送 Hello 报文和选举代表路由器。OSPF 路由器每隔一个 Hello 报文的发送间隔就发送一次 Hello 报文分组，内容包括链路的代表路由器地址 (如果还没有则为 0)、备份代表路由器地址 (如果没有则也为 0) 和邻居路由器列表。当路由器收到一个 Hello 报文时，如果发现发送该分组的路由器的 ID 还没有出现在其邻居列表中，则路由器认为其发现了一个新的邻居路由器，会将其放入邻居列表并尝试与对方建立紧邻关系。由于局域网中存在多台 OSPF 路由器时，两两路由器之间建立紧邻关系会造成较

大开销，因此，OSPF 协议会首先选举出代表路由器（DR）和备份代表路由器（BDR），该网段的所有非代表 OSPF 路由器只和代表路由器和备份代表路由器建立紧邻关系。OSPF 协议会通过 Hello 报文选出广播域内 ID 最大的路由器作为代表路由器（DR），ID 次大的路由器作为备份代表路由器（BDR），以在 DR 发生故障后替代 DR 的所有工作。路由器的 ID 是指该路由器的标识，一般会被设为该路由器的环回端口或是该路由器上的最小的 IP 地址。

- **交换链路状态数据信息。**在两台 OSPF 路由器间交换链路状态信息的过程是非对称的，首先是从两台路由器中分别选择主（master）和从（slave）路由器，然后再交换它们的链路状态数据库记录的描述信息。主从路由器的选择是通过数据库描述报文（Database Description Packet: DDP）来实现的，其中有 3 位字节分别是 I（初始化）、M（未完）和 MS（主-从）用于选择主从路由器。想要启动交换过程的路由器首先发送一个空的初始数据库描述报文，上述三个字节都设为 1。然后，另一台路由器发送一个确认分组表示同意在这一交换期间扮演从路由器角色。随后，主路由器会通过数据库描述报文向从路由器发送其数据库里记录的描述，这些 DDP 分组中 I 位被设置成 0，MS 位被设置成 1，而 M 位被设置成 1，最后一个分组例外。这些主路由器发送的 DDP 分组经过了序列编号，从路由器在收到每个分组后将发送一个确认分组，并且其中还带有从路由器数据库里记录的描述。在此交换期间，主从路由器会进一步处理它们接收到的链路状态通告记录。首先，它们会核实是否有一个记录与它们数据库中的“类型”、“广播路由器”或“链路状态 ID”是相同的，并检查记录是否有一个更大或相等的序列号。如果路由器需要这个链路状态通告，它就会通过链路状态请求分组来请求获得这些记录。当一条链路发生状态变化时，与该链路相关的路由器将通过链路状态更新报文来发送更新的链路状态信息。另一台路由器收到该报文后，会在其他所有接口进行传送，以进一步扩散该消息。
- **路由生成。**OSPF 路由器在交换链路状态信息后，会生成链路状态数据库（Link State Database: LSDB）并进一步利用 Dijkstra 最短路径算法计算最短路径树，计算出的度量（Metric）最小的路径被视为到目标网络的最短路径。在具体配置 OSPF 路由器时则可根据实际情况，如链路带宽、时延或经济上的费用来设置每条链路的 Metric 大小。每个 OSPF 路由器都

会周期性地发送链路状态通告，或在路由器状态发生变化时发送链路状态通告。OSPF 路由器在接收到包含有新信息的链路状态更新报文后，将更新自己的链路状态数据库并重新计算路由表。

1.1.2 OSPF 协议安全威胁分析

OSPF 协议基于最短路径算法和链路状态通告 (LSA) 来计算域内路由路径，以构建各种网络环境下的域内拓扑。为提高路由计算效率，OSPF 协议在设计上仅使用了一种简单的 LSA 通告验证机制，即基于每个 LSA 中的 sequence number、age 和 checksum 字段来判断 LSA 的真实性。然而，该机制使得攻击者可以轻易预测 LSA 中的字段值来伪造虚假 LSA，进而操纵其他域内路由器的路由决策过程。另一方面，当域内路由器发现错误的 LSA 通告时，会立刻发送新的 LSA 通告来对错误信息进行覆盖（即 Fight Back 机制）。但 OSPF 协议在设计上为 LSA 通告的产生设定了一个最小发送间隔，倘若攻击者以小于此间隔的发送间隔往网络中不断广播虚假的 LSA 通告，域内路由器将无法正常执行 Fight Back 机制，导致错误路由信息不能被纠正。同时，攻击者也可以反过来利用虚假 LSA 通告会触发 Fight Back 机制这一特性，通过不断发送虚假 LSA 通告来引发域内路由震荡，导致路由难以收敛。除却协议本身的设计缺陷，不同厂商在 OSPF 协议实际开发和配置过程中的差异性同样会导致额外的安全漏洞。例如，部分厂商开发的 OSPF 协议在 LSA 通告序列号达到最大值时，并未先将该 LSA 信息清空再为新 LSA 通告重新赋予最小序列号，导致处于最大序列号值的 LSA 通告信息将一直保留在各路由器中，影响后续 LSA 通告的有效性。另外，OSPF 协议过于简单的密钥配置和管理机制也大大降低了攻击者对连接密钥的猜测难度。

本节接下来将从 OSPF 的协议设计，以及实现和配置两方面，具体介绍 OSPF 协议存在的安全漏洞。

1.OSPF 协议设计的安全缺陷

由于在设计协议时的安全考量不足，OSPF 协议中的多个运行机制均存在安全漏洞。这些机制具体包括：

- **LSA 通告验证机制。**为提高路由计算效率，保证域内网络拓扑的收敛速度，OSPF 采用了一种简单的 LSA 通告验证机制，即检查 LSA 通告中的 sequence number、age 和 checksum 字段来判断两个 LSA 通告是否相

同。但这种简单的设计会导致攻击者通过预测上述字段值来伪造 LSA 通告。在该机制中，sequence number 序列号更新时会固定加 1，而具体时间间隔不超过 15 分钟的两个 age 字段则被认为是相同的。此外，该机制会基于不包括 age 字段在内的 LSA 通告内容来计算 checksum 字段值。因此，攻击者可基于上一个 LSA 通告内容来伪造 checksum，从而令内容不同的 LSA 通告拥有相同的校验字段。只要攻击者伪造的 LSA 通告与真实的 LSA 通告拥有相同的 sequence number、age 和 checksum 字段，即使具体的通告内容不一致，OSPF 协议仍会认为伪造的 LSA 通告是真实通告的有效复制。

- **LSA 通告存储机制。**在接收到 LSA 通告时，OSPF 协议会不经验证地直接将收到的 LSA 通告存储进链路状态数据库 (LSDB) 中。该设计存在一个安全隐患，即由攻击者构造的虚假 LSA 通告也同样会被存储进 LSDB 中。虽然虚假 LSA 的域内链路信息通常不会参与路由器对域内拓扑的具体计算过程，但攻击者依然可以通过源源不断地发送此类虚假 LSA 通告而使 LSDB 产生溢出问题，进而导致真实的 LSA 通告无法被存储进 LSDB 中，破坏域内拓扑的正常计算。
- **Fight Back 机制。**在 OSPF 协议的设计中，当一个域内路由器接收到了自称由该路由器产生的一条 LSA 通告，且通告内容与该路由器当前实际的路由状态信息不一致时，该路由器会重新发送一条新 LSA 通告以覆盖这条错误的旧 LSA 通告。此过程被称为 Fight Back 机制，可以在一定程度上防御攻击者对 LSA 通告的伪造攻击。然而该机制在设计上同样存在两个安全漏洞：(1) OSPF 协议给 LSA 通告的发送规定了一个最短时间间隔 MinLSInterval。倘若攻击者以小于 MinLSInterval 的间隔在域内网络中不断发送虚假的 LSA 通告，则路由器无法正常发送用于覆盖的新 LSA 通告，导致 Fight Back 机制被突破，路由遭到攻击者污染；(2) 攻击者还可以不断发送虚假的 LSA 通告，反复触发路由器的 Fight Back 机制以产生大量的 LSA 通告，造成网络中的路由链路震荡，影响域内路由系统的可用性。
- **指定路由器机制。**在 OSPF 协议的设计中，多路访问链路上会指定一个路由器来代表某子网向其他路由器发送 LSA 通告，以减少域内网络中的重复路由信息。指定路由器是由 OSPF 协议在对比不同域内路由器配置参数（如路由器 ID 的大小）的基础上自动选择的。然而，该过程同样存

在安全漏洞：(1) 指定方式过于简单，攻击者可以通过伪造路由器 ID 等方式轻易操控路由器的指定过程；(2) 被选为指定路由器的主路由器在发送 OSPF 的数据库描述报文时不会检查从路由器的消息内容，而从路由器会基于主路由器的消息内容来回复对应序号的同步消息。因此，攻击者在伪装为某个区域的路由器后，即使其实际位置不处于该区域内，也同样可以欺骗主路由器来操控区域内的路由拓扑构建过程，实现流量监听或劫持的不法目的。

2. OSPF 协议不当配置造成的安全问题

OSPF 协议的正常使用过程中，域内网络管理员需要对其进行多项配置。但不当的协议配置同样会导致一系列安全问题：

- **链路认证配置。**为保证链路中所传输的数据包的合法性，OSPF 协议采用了链路认证机制。在该机制的设计中，所有连接到同一链路的域内路由器会使用同一链路密钥，对从链路上接收的 LSA 通告进行验证。由于 OSPF 协议并未设计具体的链路密钥管理机制，域内网络管理者需要为每条链路自行配置相应密钥。但在实际使用中，很多管理员往往会为不同链路配置相同的密钥。如果攻击者能够截获特定 OSPF 数据包并获取相应的链路密钥，就能进一步绕过其他链路的认证机制，发送伪造的数据包。
- **单路径配置。**当某一域内路由器接收到关于 LSA 通告的 ACK 消息时，路由器会在重传列表中寻找该消息对应的 LSA 通告实例。若实例不存在，则路由器会忽略该 ACK 消息。这样的设计在单路径配置下存在安全漏洞：若路由器 A 到 B 只存在单一路由路径且攻击者伪造了 A 的 LSA 通告，则 B 在接收到该虚假 LSA 通告后发送的 ACK 消息不会触发 A 执行 Fight Back 机制，进而导致该虚假 LSA 通告被 B 采纳。

3. 自适应域内路由协议的原生安全问题

除却 OSPF 协议自身设计和不当配置所导致的安全问题，OSPF 作为一种典型的自适应式路由协议，同样存在自适应路由协议的原生安全问题。具体来说，自适应路由协议在遇到链路和节点故障时，会自动发送故障通告，接收到故障通告的节点则会更新其路由信息并重新计算路由，最终令整个网络的路由状态发生变化，直至重新收敛到稳定状态。然而，这种特性意味着局部链路状

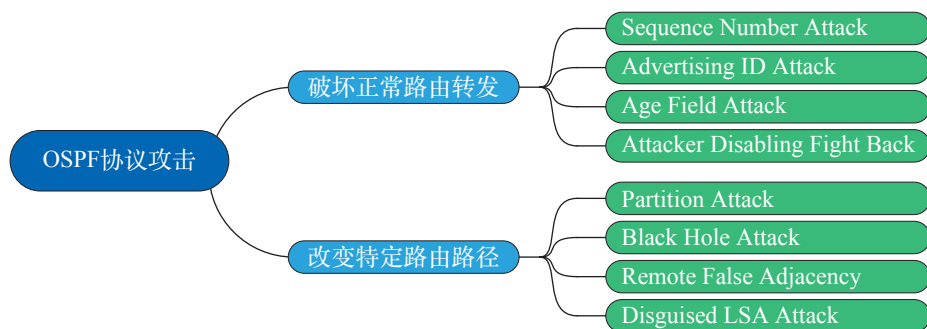


图 1.1 OSPF 攻击分类

态的改变会在较长时间内影响大范围的网路路由状态。因此，倘若攻击者掌握了包括拓扑结构和链路权值在内的关键网络配置信息，他们就可以通过改变特定链路状态（例如直接切断链路，或进行拒绝服务攻击）来触发自适应协议的路由重新计算过程，使得其生成符合攻击者期望的特定路由路径，实现对流量的监听或劫持。

1.1.3 针对 OSPF 协议安全漏洞的攻击

针对上文所介绍的 OSPF 协议安全漏洞，目前存在多种攻击方式。根据攻击目的，我们可以将这些攻击方式分为两大类：（1）破坏 OSPF 协议的正常路由转发功能，以造成拥塞、丢包或拒绝服务的攻击；（2）改变 OSPF 协议中特定路由路径，以实现对流量的监听或劫持的攻击。具体的攻击分类如图1.1所示，在下文我们将对它们进行分别介绍。

1. 破坏 OSPF 协议正常路由转发功能的攻击

- **Sequence Number Attack^[8]**。OSPF 协议中 LSA 通告的 sequence number 字段是长度为 4 字节的补码，可用于判断两个不同 LSA 的新旧程度，即产生时间越新的 LSA 通告，其 sequence number 越大。域内路由器会为第一个产生的 LSA 通告分配值为 0x80000001 的 sequence number，且每产生一个 LSA 该字段加 1，最大值则为 0x7fffffff。当该字段达到最大值时，路由器若再产生 LSA 通告，就会导致该字段溢出并重新变为最小值。在正常情况下，该字段由最小值增长至最大值大概需要花费 340 年的时间，因此我们可忽略 sequence number 字段的溢出问题。但攻

击者可直接将虚假 LSA 通告的 sequence number 字段设置为最大值,此时其他正常 LSA 通告会因字段值均小于最大值而被路由器错误地丢弃,导致虚假 LSA 通告污染路由表,直到该虚假 LSA 通告的生命周期结束(可长达 1 小时)。

- **Advertising ID Attack^[4]**。由于 OSPF 协议未明确定义路由表计算是否应该使用到宣告路由器 ID,部分路由器厂商在实现 OSPF 协议时仅使用了链路状态 ID 来计算路由表。对于此类域内路由器,攻击者可以伪造链路状态 ID 与被攻击路由器 ID 相同,而宣告路由器 ID 与被攻击路由器 ID 不同的虚假 LSA 通告。在这种情况下,该 LSA 通告即使被发送给被攻击路由器,也不会触发被攻击路由器的 Fight Back 机制,因此可以替代正确的 LSA 通告参与其他域内路由器的路由表计算,破坏正常的路由转发功能。
- **Age Field Attack^[3]**。LSA 通告的 age 字段用于记录该通告在域内路由系统中的存在时长,其最大值被记为 MaxAge。若一个 LSA 通告的 age 字段增加到 MaxAge,路由器会丢弃该 LSA 通告,并同时发送洪泛消息来提醒所有的其他路由器。针对该特性,攻击者可以注入 age 字段为 MaxAge 的虚假 LSA 通告,不断触发路由器产生洪泛消息和进行路由状态更新,大量消耗路由系统可用资源,降低路由系统可用性。
- **Attacker Disabling Fight Back^[3]**。RFC 2328 规定域内路由器产生 LSA 通告(包括 Fight Back 机制所产生的 LSA 通告)的最小时间间隔(即 MinLSInterval)为 5 秒^[5]。如果攻击者以小于 5 秒的间隔不断发送伪造的 LSA 通告,就可以使得 Fight Back 机制所产生的 LSA 通告失效,从而令伪造的 LSA 通告绕过 Fight Back 机制而污染路由表,破坏正常的路由转发功能。

2. 改变 OSPF 协议特定路由路径的攻击

- **Partition Attack^[6]**。由于 OSPF 协议的 LSA 通告验证机制存在漏洞,攻击者可以伪造出与原 LSA 通告内容不一致,而 sequence number、checksum、age 字段却一致的虚假 LSA 通告。当其他路由器接收到这些虚假 LSA 通告时,会基于其中的虚假且不一致的路由信息计算各自的域内路由拓扑,很容易导致路由器间出现环路或非最优路由路径。

- **Black Hole Attack**^[3]。攻击者可以在控制某台域内路由系统中的路由器后，构造虚假 LSA 通告以向其他路由器宣称该路由器是某个子网的网关，而这不会触发 Fight Back 机制。其他路由器在采纳该虚假 LSA 通告后，会将流向该子网地址的网络流量错误地转发至这台被攻击者所控制的路由器。攻击者可以将这些流量直接丢弃，造成流量黑洞（Black Hole），破坏对该子网地址主机的正常网络访问。
- **Remote False Adjacency**^[7]。在 OSPF 协议中，攻击者在知悉每条链路的密钥后，即可构造虚拟的路由器身份并与指定路由器交换链路信息来建立紧邻关系，从而获取主路由器身份来操控域内路由拓扑。攻击者首先选定子网中构造一个拥有该子网地址的虚拟路由器，随后操控虚拟路由器向受害者路由器（即网络中的指定路由器）发送 OSPF 协议的 Hello 消息，并在消息中伪造一个较大的路由 ID，以欺骗受害者路由器并取得主路由器的身份。在收到 Hello 消息后，受害者路由器会向虚拟路由器的地址回复 DDP 消息，以期建立紧邻关系。攻击者则会假装收到 DDP 消息，并操纵虚拟路由器向受害者路由器持续发送 DDP 消息。由于受害者路由器的 ID 通常小于虚拟路由器的伪造 ID，受害者路由器便会转为从路由器的身份。攻击者一方面向受害者路由器持续发送消息，以维持紧邻关系和主路由器身份，另一方面即可凭借欺骗得到的主路由器身份操纵域内路由的计算过程。
- **Disguised LSA Attack**^[7]。OSPF 协议中，Fight Back 机制所发送的 LSA 通告（称为 Fight Back LSA 通告）的 sequence number、checksum、age 字段是可预测的。针对这一特性，攻击者可以构造在这 3 个字段上与 Fight Back LSA 通告相同的 disguised LSA 通告，并先于 Fight Back LSA 通告的发送时间发送。由于运行 OSPF 协议的路由器在接收到两个“相同的”（基于 sequence number、checksum、age 三字段是否相同来判断）LSA 通告时，只会采纳相对更早发送的那个，网络中其他路由器会先采纳 disguised LSA 通告，而忽略真正的 Fight Back LSA 通告。如此，攻击者即可在网络中发送伪造的 LSA 通告，并令 Fight Back 机制无效化，进而污染路由表，操纵域内路由的计算过程。在具体的攻击过程中，攻击者会首先发送 trigger LSA 通告以触发路由器的 Fight Back 机制。trigger LSA 通告的 sequence number 只需要大于网络中受害者路由器的当前 LSA 序号。disguised LSA 通告的 sequence number 是 trigger

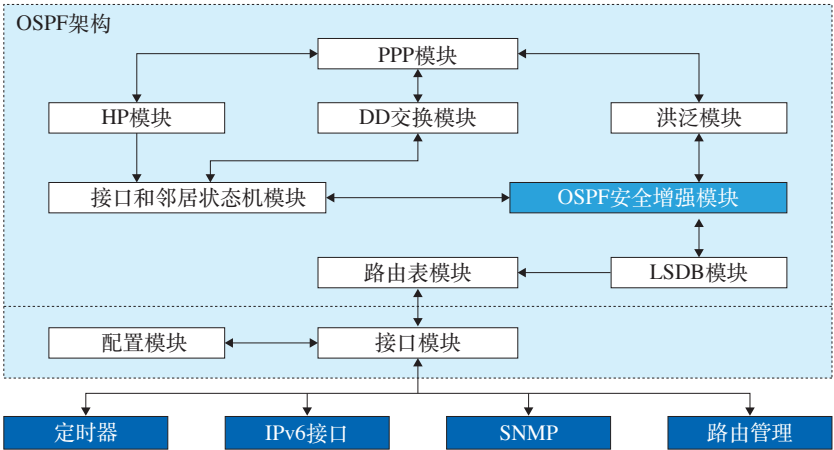


图 1.2 OSPF 安全增强模块与其他 OSPF 模块的关系

LSA 的序号加 1，同时 age 字段的时间差不超过 15 分钟。此外，还需要通过穷举搜索来伪造 disguised LSA 通告的链路状态信息，使得 disguised LSA 通告与 Fight Back LSA 通告的 checksum 相同。在实际攻击过程中，disguised LSA 通告和 trigger LSA 通告的发送时间间隔通常设为 1 秒，以使得伪造的 LSA 通告能绕过 Fight Back 机制，被大部分域内路由器所采纳。

1.1.4 OSPF 协议安全增强方案

为防御前文介绍的多种针对 OSPF 协议的攻击，本节介绍一种 OSPF 协议安全增强方案 [8]。如图1.2所示，该方案在现有 OSPF 的洪泛模块、LSDB 模块、接口与邻居状态机模块间增加了一个安全增强模块，负责对 OSPF 安全相关问题的统一处理。

如图1.3所示，该方案中的 OSPF 安全增强模块由三部分组成：协议安全配置、协议安全完善和辅助安全增强。协议安全配置部分负责为不同的链路分配不同的密钥，来解决传统 OSPF 协议因链路密钥配置简单和共用所导致的一系列安全问题。同时，该部分在 LSA 通告中添加随机化的字段来防止攻击者对 LSA 通告的预测，避免攻击者通过预测和伪造 LSA 通告所发动的一系列攻击。协议安全完善部分主要关注于增强 LSA 通告验证流程的安全性，其在 LSA 通告中添加了基于 LSA 内容的哈希值，并提出了针对 sequence number 和 age

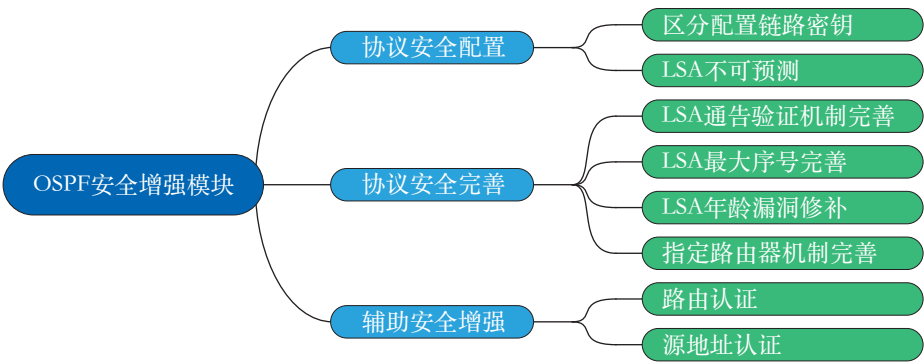


图 1.3 OSPF 安全增强模块的组成

字段实现漏洞的修正机制。此外，辅助安全增强部分则通过对路由和源地址进行认证，以提高域内路由协议的安全性。

1. 协议安全配置

- **区分配置链路密钥。**OSPF 协议在设计上未对链路密钥的管理方式进行明确规定，多数实际场景中的 OSPF 链路密钥是由网络管理员进行人工配置，甚至是未配置的，极易被攻击者窃取和利用。因此，对 OSPF 协议进行区分式链路密钥配置，即为不同的链路配置不同的密钥，可以有效提高域内网络的路由安全性。即使攻击者窃取了某条链路密钥，也无法威胁域内网络中的其他链路。
- **LSA 不可预测。**为防止攻击者通过预测 LSA 通告内容来发动攻击，该安全增强方案在 LSA 通告中增加了一个由随机数值所组成的虚拟链路字段。该字段可以影响 LSA 通告的 checksum 计算，使得 LSA 通告无法被攻击者预测。此字段的增加并不会对路由表的计算过程带来额外的计算开销，只会少量增加 LSA 通告的数据库存储开销。

2. 协议安全完善

- **LSA 通告验证机制完善。**为增加 OSPF 协议 LSA 通告验证机制的安全性，本方案在 LSA 消息中额外添加了一个记录有整个 LSA 通告（age 字段除外）哈希值的验证字段。在对两个 LSA 通告进行内容验证时，首先比较 sequence number、age 和 checksum 三个字段是否相同。如果不完

全相同，则采纳时间上较新的通告；如果相同，则进一步比较两通告的哈希值验证字段。对于哈希值不同的场景，则同样采纳时间上较新的通告。若哈希值依然相同，则将较新的通告视为重复发送的副本并丢弃。这种安全增强的 LSA 通告验证机制一方面可以加大攻击者伪造 LSA 通告的难度，同时也可以消除伪造 LSA 攻击造成的持续负面影响。

- **LSA 最大序号的完善。**当 LSA 通告的 sequence number 达到最大值时，路由器应当首先清除该 LSA 通告来防止攻击者基于 sequence number 伪造的攻击方式，随后再发送新的 LSA 通告。
- **LSA 年龄漏洞的修补。**当 LSA 通告的 age 字段达到最大时间时，路由器应当先清除自身存储的该 LSA 通告再发送修正 LSA 通告；若路由器原本就不存在该 LSA 通告，则不作任何转发。如此设计可以避免攻击者伪造 age 字段为最大时间的 LSA 通告来不断触发路由器发送清除消息，避免链路震荡。
- **指定路由器机制的完善。**当两个域内路由器尝试建立链路关系时，从路由器需验证主路由器是否查看了消息内容。从路由器在接收到主路由器的数据库描述信息报文 (DDP) 时，会以概率 p 发送下一条 DDP 消息， $1-p$ 的概率发送上一条 DDP 消息。如果主路由器查看了 DDP 消息的具体内容，则主路由器将重发 sequence number 保持不变的 DDP。如果主路由器并未查看 DDP 消息，则重发的 DDP 的 sequence number 会加 1。因此，基于接收到的 DDP 消息的 sequence number，从路由器就可以判断主路由器是否已经查看了其发送消息的内容，进而决定是否需要建立连接。该机制可以有效防范攻击者通过伪造虚拟路由器来获取主路由器的身份。

3. 辅助安全增强

- **路由认证。**要求域内网络中的每个路由器，都基于配置的链路密钥来验证 LSA 通告的真实性。因此，只要攻击者未能窃取链路密钥，就不能注入伪造 LSA 通告来发动攻击。
- **源地址认证。**在域内网络中维护一个安全可靠的源地址列表，用于对路由器接收到的 LSA 消息进行源认证，并对未知来源的 LSA 通告进行告警以提示管理员处理。该机制可以阻止攻击者在网络中随意注入虚假来源的 LSA 消息，以避免路由计算过程被攻击者操纵。

1.2 针对域间路由协议 BGP 的攻击和防御

为实现不同网络之间的互联互通，需要采用域间路由协议（Inter-domain Routing Protocol）来为边界路由器计算到达不同网络的最优路由路径。当前，边界网关协议（Border Gateway Protocol: BGP）是唯一被广泛部署使用的域间路由协议，互联网事实上的域间路由标准便是由 RFC 4271 等定义的 BGPv4^[9]。该标准规范了自治系统（Autonomous System: AS）之间交换路由和可达性信息的行为准则，是互联网得以正常运作的基础设施之一。BGP 协议是一种路径向量协议，部署了 BGP 的 AS 会宣告其拥有的 IP 地址前缀，并通过和相邻 AS 交换路由控制信息，结合多层次的本地策略来计算最佳路由路径和更新路由表。然而，BGP 协议在设计时缺乏足够的安全考量，无法验证路由宣告信息的真实性。该缺陷导致域间路由器会接收并转发那些由攻击者伪造或路由误配置所产生的错误路由信息，进而计算出错误的路由路径^[10]。攻击者可利用该缺陷来操纵互联网流量的转发过程以实现不法目的，如中断网络访问、发送垃圾邮件、监听流量等。近些年，针对 BGP 的网络攻击事件不断发生，对全球互联网空间的安全稳定造成了严重威胁。因此，为维护互联网的正常互联互通功能，研究 BGP 协议所面临的安全威胁并提出相应的防护机制至关重要。

在本节中，我们将首先介绍 BGP 协议的基础知识和面临的典型安全威胁，并且将从检测虚假 BGP 路由宣告和增强 BGP 协议自身安全性的角度，来分别介绍经典的 BGP 协议安全防护机制。最后，我们将介绍域间路由安全领域的前沿研究进展：基于机器学习的异常路由与攻击检测技术和一种基于可验证转发承诺的安全域间路由协议。

2008 年 2 月，巴基斯坦电信（AS17557）虚假宣称其拥有地址前缀 208.65.153.0/24，劫持了全球互联网大范围内用户对 YouTube 的访问流量^[11]。

1.2.1 BGP 协议基础知识

BGP 协议是一种用于自治系统之间的分布式动态路由协议，并且是目前唯一的域间路由协议，所有商用核心路由器必须支持该协议。BGP 协议的主要功能是在实现了 BGP 协议的自治系统之间交换网络可达性信息，包括到达特定网络所需穿越的自治系统列表，最终实现不同网络之间的互联互通。现在所说的 BGP 协议一般是指 BGPv4 协议^[9]，其提供对无类别的域间路由的支持，通过消除地址类的概念来为路由信息的处理提供了更多的灵活性。并且，BGP 协议中还包括了路由聚合机制，也支持对路由路径 AS_Path 的聚合。

BGP 协议的交互过程主要有两种：（1）同一自治系统或相邻自治系统中的 BGP 路由器之间交互信息；（2）BGP 路由器与同一自治系统中运行域内

路由协议的路由器交互信息，如 OSPF 和 RIP 等，此种交互通常需要路由器具有路由管理和路由重分配功能。BGP 路由器之间的交互过程主要使用四种消息类型：OPEN、KEEPALIVE、UPDATE 和 NOTIFICATION 消息。其中，OPEN 消息用于 BGP 路由器之间建立连接和协商参数。KEEPALIVE 消息则被 BGP 路由器用于对特定消息的响应，或在没有路由信息发送时维持 TCP 链路的活跃状态。UPDATE 消息则是用于 BGP 路由器之间交互路由信息。NOTIFICATION 则负责报告错误，BGP 路由器发送此类消息后通常就会关闭之间的 TCP 连接。

两个 BGP 路由器在建立 TCP 连接后会进行参数协商，然后通过交换两者完整的路由表来交互路由信息，之后则会采用增量更新的方式，即只声明新的路由路径 (Advertise) 或撤销无效的路由路径 (Withdraw)。每个 UPDATE 消息只能声明一条新路由，其中包含了路径属性 (Path Attribute) 和网络可达性信息 (Network Layer Reachability Information: NLRI)。AS_Path 即是路径属性之一，其记录了通向最终目标网络所需经过的自治系统列表。网络可达性信息则由一个或多个 <Length/IP-Prefix> 二元组构成，每个二元组都描述了一个通过路径属性中的 NEXT HOP 属性所指明的网关可以到达的网络。此外，每个 UPDATE 消息可撤销一条或多条路由信息，被撤销的路由同样通过二元组 <Length/IP-Prefix> 来表示。

BGP 协议的路由计算过程包括两个阶段，路由合成 (Route Synthesis) 和路由选择 (Route Selection)。路由合成是指对收到的路由信息施加策略，其是 BGP 协议最重要的特性和功能之一，能够让各个自治系统独立决定如何管理和控制自身的数据流和网络资源。BGP 协议的策略又分输入策略 (Import Policy) 和输出策略 (Export Policy)，只有输入策略允许的路由信息才会进一步通过路由选择过程来确定最优路由，再放入路由信息库中。而路由信息库中的最优路由在发送给邻居路由器之前，也同样会经过输出策略的检查，即只有输出策略允许的路由信息才会发送给邻居路由器。一般来说，BGP 协议中的一条路由通常包含有：网络层可达信息 (NIRL)、下一跳地址 (Next Hop)、路由路径 (AS_PATH) 和本地优先权 (LOCAL_PREF) 等属性。基于这些属性，BGP 协议的路由选择过程通常为：(1) 如果两条路由 NLRI 值相同，那么选择 LOCAL_PREF 更高的路由；(2) 如果两条相同的路由的 LOCAL_PREF 值相等，那么就选择具有更短 AS_PATH 的路由；(3) 如果 AS_PATH 长度也相等，优先选择到出口路由器更近的路由；(4) 如果到出口路由器距离也相等，选择 route_id 较小的路由器发送来的路由。

1.2.2 BGP 协议面临的典型安全威胁

BGP 协议无法验证路由信息的真实性，这一特点会导致两类安全威胁：路由劫持和路由泄露。它们都会对 BGP 协议的正常运行造成严重的负面影响。

1. 路由劫持

在 BGP 协议中，自治系统之间通过域间路由器发送的 BGP 消息来交换控制信息。其中，表达路由宣告或路由撤回的 BGP 消息称为更新消息 (UPDATE)。在本书中，如不作额外说明，“BGP 宣告”和“BGP 路由宣告”均指表达路由宣告（而非路由撤回）的更新消息。一个 BGP 路由宣告，包含有一个 IP 地址前缀 (IP Prefix) 和一个自治系统号所组成的序列 (AS_Path)，其代表了通向该 IP 地址前缀的路由路径。并且，AS_Path 中最后的自治系统拥有该地址前缀的所有权，是该地址前缀的最初宣告者，因此也被称为该地址前缀的源 AS (Origin AS)。

在 BGP 劫持攻击中，攻击者可以操纵某个自治系统中的域间路由器发送伪造的 BGP 宣告，在伪造的 BGP 宣告中直接改变受害地址前缀的源 AS 号来宣称所有权。邻居路由器将伪造宣告传播至互联网后，部分域间路由器可能会采纳该伪造宣告，导致对该地址前缀的网络流量被错误地转发给攻击者所控制的自治系统。因此，此种攻击方式也被称为“前缀劫持”。由于攻击者所宣称的地址前缀和受害自治系统所拥有的地址前缀一致，此种攻击方式不仅容易被发现，部分域间路由器也可能不采纳伪造的 BGP 宣告而导致攻击失败。一种更隐蔽的劫持方式则是针对受害地址前缀宣称一个更明细的子地址前缀，即“子前缀劫持”。由于 BGP 协议采用了最长前缀匹配机制，前缀长度更长的子地址前缀会优先被其他域间路由器采纳，从而增加了攻击影响范围和成功率。此外，攻击者也可以宣称其拥有一条同样通往受害地址前缀源 AS 的新路径，且该新路径相比当前真实路由路径更短（无论这条新路径是否真实存在）。由于路由器往往倾向于选择更短的路由路径，攻击者所伪造的路由路径就很可能被采纳。

路由劫持攻击可用来达成多种恶意目的，具体可分为三类：流量黑洞、伪装攻击和流量截取。流量黑洞 (Blackholing) 是指攻击者将访问受害地址前缀的网络流量劫持至不正确乃至不存在的自治系统，导致流量被丢弃。但需要注意的是，此种攻击方式也可以用来防御拒绝服务攻击，即利用虚假的路由路径来丢弃拒绝服务攻击流量。伪装攻击 (Impersonation Attack) 是指攻击者将

网络流量劫持至攻击者所控制的自治系统后，伪装成受害地址前缀所对应的网络服务来响应访问流量，进而骗取用户密钥、隐私数据等信息。流量截取攻击 (Interception Attack) 则是先将网络流量劫持至攻击者所控制的自治系统，再将流量转发回受害地址前缀真正所处的自治系统，这样就可以在不中断网络访问的前提下实现流量监听等目的。流量截取攻击很难被受害者察觉，但其发动需满足多种条件而难度较高。例如，攻击者不仅需要成功劫持用户对受害地址前缀的访问流量，还要确保所控制的自治系统到受害地址前缀的真实转发路径上的所有自治系统都不受虚假宣告影响，否则无法保证被劫持的流量最终能被正常转发回受害地址前缀。

2. 路由泄露

不同于路由劫持攻击，路由泄露主要是管理员对 BGP 协议的错误配置所导致的。在 RFC 7908 中，路由泄露被定义为“Propagation of a BGP announcement(s) beyond their intended scope”，即 BGP 路由宣告在预定范围之外的传播^[12]

2019 年 6 月，瑞士公司 Safe Host (AS21217) 向中国电信 (AS4134) 泄漏了超过 7 万条路由路径信息，导致全球大量互联网流量被错误导向中国电信。

BGP 路由宣告的预定传播范围取决于路由器的宣告输入和输出策略，而这些策略主要由自治系统间的商业关系决定。通常来讲，不同组织的相邻自治系统之间存在三种商业关系：“Provider-to-Customer”、“Customer-to-Provider”，和“Peer-to-Peer”。其中，作为 Customer 的自治系统会向作为 Provider 的自治系统付费购买网络流量转发服务，而同为 Peer 的自治系统则相互免费转发对方流量。因此，Provider 的路由器会将其掌握的所有地址前缀的路由路径通告给其 Customer 的路由器，而 Customer 的路由器只会向 Provider 的路由器通告其自身和它的 Customer 的路由器所拥有地址前缀的路由路径。此外，两个 Peer 的路由器之间只会交换它们自己和它们的 Customer 的路由器所拥有地址前缀的路由路径。当某台 BGP 路由器不遵循上述规则，将特定路由路径通告给不应当通告的相邻自治系统的路由器时，就会造成 BGP 路由宣告在预定范围之外传播，即路由泄露。例如，某台路由器将其 Provider 通告给它的路由路径转给另一台 Peer 邻居的路由器。路由泄露会让 BGP 路由器选择错误的路由路径，从而导致网络流量被导向原本不应负责转发的路由器，不仅会降低网络性能，还有可能使得流量被错误地丢弃。此外，路由泄露还会导致不当的流量计费，使自治系统的经济利益受损。

1.2.3 虚假路由宣告检测

由攻击或误配置产生的虚假 BGP 宣告会造成域间路由的异常变动，严重危害域间路由系统的稳定运行。准确发现并消除这些虚假 BGP 宣告，对维护互联网基础路由设施安全具有重要意义。当前，虚假 BGP 宣告检测方法可大致分为三类：基于控制面（Control-plane）匹配、数据面（Data-plane）探测，和结合二者的混合式方法。控制面方法通常是被动地收集路由信息，如拟保护地址前缀的路由路径，并和正常路由信息比对来发现异常路由变动。此类方法虽然有着易于部署和反应速度快的优点，却往往不够准确，容易产生误报。数据面方法则会主动且持续地探测互联网中的数据传输路径是否发生了不正常的改变，但是该类方法不仅可拓展性欠佳、探测开销高，也很难发现针对子地址前缀的路由劫持攻击。混合式方法则结合了二者的检测思路来取得更好的检测性能。本节将介绍代表性的控制面和数据面检测方法，以及一种结合了两类方法优点的混合式方法 Argus。

1. 控制面检测方法

PHAS^[13] 是一种基于路由路径匹配的前缀劫持攻击检测与告警系统，由实时 BGP 更新信息采集、用户注册、前缀攻击检测和告警通知与过滤模块组成。在检测过程中，其会检查接收到的路由路径是否先前已经存在来产生告警，并采用了特定的滑动窗口算法来减少重复告警数量。在接收告警的本地用户处，PHAS 同样定义了一系列启发式规则来进一步对接收到的告警进行筛选，以减少误报。Li 等人^[14] 提出了一种基于伙伴关系的地址前缀异常检测系统，其核心思想为：对于某项需要保护的地址前缀，与其行为表现相似的地址前缀可被称为伙伴，当需要保护的地址前缀产生异常时，伙伴之间会出现行为差异。域间路由系统正常运行时，到两者的路由路径相似。当发生合法的路由变动时，通向两者的路由路径会发生相似的变化。而当前缀劫持攻击等异常事件发生时，通向需要保护地址前缀的路径会发生变化，而至伙伴的路径则保持不变。ARTEMIS^[15] 是一种能够检测多种前缀劫持攻击的系统，包括前缀劫持、路径劫持、子前缀劫持攻击，其检测过程为判断 BGP 路由宣告中的路由路径和地址前缀所属自治域是否和预先配置的正常路由信息相符，并设计了两条启发式规则来进一步验证路由宣告中的自治系统间链路（AS-link）列表是否正常。

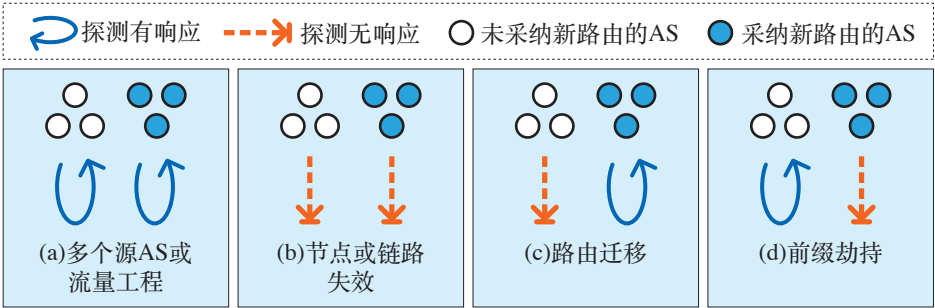


图 1.4 不同路由变动事件下的数据面可达性区别

2. 数据面检测方法

iSPY^[16] 是一种轻量化的前缀劫持攻击检测系统，部署于需要保护的自治系统网络内部，能够对该自治系统相关的地址前缀进行实时的劫持攻击检测。iSPY 的检测原理为：受攻击影响的前缀地址内的主机，将无法访问大多数的互联网地址，其回复包将会被错误地沿劫持后的路径导向未知网络节点。因此，可以通过检查网络内部主机至外部地址的数据可达性来判断自身网络地址前缀受到劫持攻击的可能性。Zheng 等人^[17] 设计了一种分布式的前缀劫持攻击检测系统，其能够检测流量黑洞、伪装者和流量截取类攻击。该系统需要为每个拟保护的地址前缀在互联网上选择多个观测点，和一个离该地址前缀很近但不相同的参考地址。每个观测点会定期检查到拟保护地址前缀的网络距离。当观测点发现距离显著改变时，其会进一步检查到拟保护地址前缀和参考地址的路由路径是否相似。如不相似，则产生告警。

3. 混合式检测方法 Argus

Argus^[18] 的检测原理基于各类路由变动事件会对数据面可达性造成不同的影响。如图1.4所示，在各类路由变动事件发生和产生的新路由路径被互联网中部分 AS 的路由器采纳后，该路径对应地址前缀的数据可达性有以下几种情况：

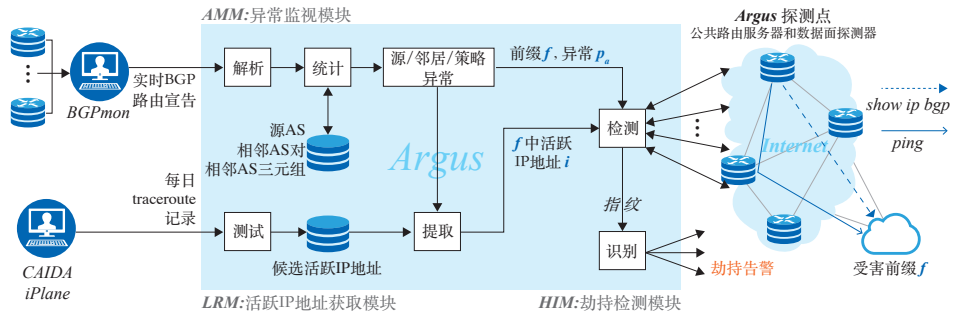
- 当该地址前缀存在多个源 AS 或互联网中部署了流量工程策略，此时未采纳和采纳了新路径的路由器都可以正常访问该地址前缀。
- 当通向地址前缀唯一路径的某个节点或链路失效，此时不存在通向地址前缀的有效路径，因此未采纳和采纳了新路径的路由器都无法访问该地址前缀。

- 当路由迁移时（拥有地址前缀的源 AS 发生变化或新的路由路径片段出现），采纳了新路径的路由器可以访问该地址前缀，而未采纳新路径的路由器无法访问。
- 当新路由路径是攻击者所构造的虚假路径时，采纳了新路径的路由器无法访问地址前缀，而还未采纳新路径的路由器依然可以访问。

可以看出，不同路由器中控制面路由路径和数据面数据可达性之间的关联性能区分不同的路由变动事件，包括识别能产生虚假路由路径的劫持攻击。在此基础上，Argus 具体采用了 `show ip bgp` 命令来获取路由器的 BGP 路由表信息，并使用 `ping` 命令来检查对地址前缀的数据可达性。如图 1.5 所示，Argus 由三个模块组成：异常监视模块（Anomaly Monitoring Module: AMM）、活跃 IP 地址获取模块（Live-IP Retrieving Module: LRM），和劫持检测模块（Hijacking Identification Module: HIM）。

异常监视模块从 BGPmon 接受全球路由器的实时 BGP 路由宣告，并检测其中的路由路径是否包含了异常的源 AS 或路径片段，其考虑了三种异常状况：源异常、邻居异常，和策略异常。该模块首先维护了一个数据库以记录每个地址前缀的源 AS、所有路由路径中出现过的相邻 AS 对，以及相邻 AS 三元组。数据库会定期更新，以去除长期不活跃（比如超过两个月）的记录。源异常是指新接收到的路由路径中，源 AS 和该路径地址前缀在数据库中的源 AS 记录不同，或者该路径的地址前缀不存在于数据库中。此种异常是路由劫持攻击最常见的形式。邻居异常则是指新接收到的路由路径中出现了数据库中不存在的相邻 AS 对。攻击者在使用 `as-path prepend` 命令来改变路径片段，或去除路径中部分 AS 以缩短路径时，就会出现此类异常现象。此外，考虑到 AS 商业关系很大程度上决定了路由器之间的路由路径传播，路由路径中 3 个相邻 AS 所组成的片段能够反映出特定的 BGP 策略。因此，如果新路由路径中出现了之前未出现的相邻 AS 三元组，那新路由路径就很可能是攻击者伪造的而违背了现有的 BGP 策略，也同样应当被认定为异常。

对于检测到的异常路由路径所对应的地址前缀，活跃 IP 地址获取模块会从中选择一个活跃 IP 地址来作为探测目标，以检测数据可达性。基于最长前缀匹配原则，该地址应当被地址前缀覆盖，同时不被地址前缀的任何子前缀覆盖。例如，对于一个拥有三个子前缀的地址前缀 166.111.0.0/16，获取的活跃 IP 地址应当处于 166.111.64.0/18 的范围内。为实现这一目标，该模块维护了一个本地数据库来存储互联网中所有被宣告过的地址前缀中的活跃 IP 地址。这些

图 1.5 Argus 系统架构图^[18]

地址可以从 CAIDA ARK 和 iPlane 每日 traceroute 记录，以及 DNS 查询记录中获取。当向该模块请求一个特定地址前缀中的活跃 IP 地址时，模块会查询数据库中该前缀下的所有 IP 地址，进行并行探测以确定一个当前可达的 IP 地址。如果当前 IP 地址均不可达，则会返回上次查询该地址前缀的活跃 IP 地址结果。

劫持检测模块负责收集不同汇聚点的控制面和数据面信息，分析它们的关联性以判断当前的异常路由路径是否由劫持攻击导致，并且该模块使用了多个公共路由服务器来完成该任务。对于异常路由路径中的每个地址前缀，Argus 会控制每个路由服务器执行两个进程：1、收集其关于该地址前缀的控制面信息；2、对该地址前缀中被选择的活跃 IP 地址进行可达性探测。该模块会检查所有路由服务器对该地址前缀的控制面信息中是否包含了异常路由路径，并将结果记为一个向量。同时，该模块也会将所有路由服务器对被选择的活跃 IP 地址的可达性探测结果记为一个向量。当两向量表现出较强的正相关性，即大多数采纳了异常路由路径的公共路由服务器都无法访问相关地址前缀，而未采纳异常路由路径的公共路由服务器依然可以访问，此种情况会被认为发生了劫持攻击。而当两向量表现出较强的负相关性，即大多数采纳了异常路由路径的公共路由服务器都可以访问相关地址前缀，而未采纳异常路由路径的公共路由服务器无法访问，此种情况会被认为发生了路由迁移。而当两向量不相关时，则可能发生了两种情况：（1）如果绝大多数公共路由服务器均可访问目标地址前缀，则新接收到的路由路径很可能是一个正常的备份路径，常用于多源 AS、BGP 任播、路径备份、流量工程等正常目的；（2）如果绝大多数公共路由服务器不可访问目标地址前缀，则很可能是路由路径失效、路径中存在防火墙，或选择的探测地址非活跃。

1.2.4 路由协议安全性增强

通过验证 BGP 路由宣告的真实性和正确性来增强 BGP 协议自身的安全性,同样可以在一定程度上消除虚假路由宣告的负面影响。为实现这一目标,现有 BGP 安全增强方案通常基于密钥算法来验证路由宣告中的路由路径。

1. 基于密钥算法的安全 BGP 协议

SBGP 是首个安全 BGP 方案^[19],其使用公共密钥基础设施来签发 AS 和前缀证书,以实现地址前缀所属 AS 和 AS 路径的真伪验证,并通过累计签名来确保 BGP 路由通告的真实性和完整性。为了改进 SBGP 的性能,S-A 方案和 SAS 方案分别使用密钥操作的加速和顺序的累计签名来改进密码算法的性能^[20]。SPV 方案也采用对称密钥算法来实现对路由更新消息的有效签名和验证操作^[21]。这些方案有效缩短了 BGP 路由消息验证和路由收敛时间,却引入了较大的计算和内存开销。为解决该问题,研究者提出了一系列的方案^[22, 23]。Secure origin BGP (SoBGP) 采用了一种分布式的信任模型^[22],并引入了一类新的 BGP 消息来传递证书,但不能防范攻击者所发布的虚假路由路径。Pretty secure BGP (psBGP) 使用一个签名的前缀断言列表 (PAL) 来携带 AS 号和 IP 前缀的绑定,以提高对路由更新消息的检测效率,并同时降低了路由更新消息的通信开销^[23]。但由于不同的 IP 前缀可能会来源于不同层次的 ISP, psBGP 比较难满足真实互联网的部署需求。此外,Shi 等人^[24]通过使用可信计算 (TC) 技术提出了一个基于内存验证的安全路由方案 (BIND),但其在收到路由更新后需要实时验证邻居路由器的内存,导致较大的验证延迟和内存开销,并会造成 BGP 收敛性能的恶化。例如,为了验证从一个邻居 AS 发来的路由通告, BIND 需要进行很多轮基于消息认证码的密钥加解密操作。Butler 等人^[25]提出的路径验证方案利用了 BGP 路由通告的局部性,通过哈希函数来避免对一个路由更新的多次签名验证操作,从而有效降低了路由验证开销^[10]。但该方法需要在路由更新中携带哈希值,因此其通信开销依然大于 SBGP^[25]。

总的来说,这些 BGP 安全增强方案通常需要引入大量的计算开销和内存开销,对路由性能存在负面影响,难以在真实互联网中部署应用。此外,这些 BGP 安全方案无法检测路由的控制面和数据面的一致性,因而通常无法防御基于数据面的攻击^[26]。

2. 基于可传递信任关系和路由验证规则的安全域间路由协议 TBGP

TBGP^[27] 是一种基于可传递信任关系和路由验证规则的安全域间路由协议, 相比传统的安全 BGP 协议有着更低的计算开销和网络资源消耗, 并支持增量部署。TBGP 能实现以下安全目标: (1) 可验证一个自治系统是否是其 AS 号的真正所有者并且授权使用这个 AS 号; (2) 可验证一个路由器是否授权通告一个前缀, 并且确保 BGP 路由器和一个 AS 号相关联; (3) 可验证到达地址前缀的路由路径是沿着该路径中的 AS 序列顺序通告得到的; (4) 可验证一个自治系统 AS 是否授权产生一个 IP 地址前缀。

传统 BGP 协议提供了两种可配置的规则过滤器, 即入口过滤器和出口过滤器, 来分别实现对收到和发送路由通告的过滤。网络服务提供商可以采用这些过滤器, 来确保它们的路由器仅接收从指定邻居学到的路由和声明到指定邻居的路由。因此, 在理论上, 如果所有提供商都正确执行这些操作, 则网络中的路由器均可有效防御路由攻击。TBGP 通过构建一种可以传递的信任关系实现了这一目标。在 TBGP 协议中, 一台 BGP 路由器如果在出口过滤器成功验证了路由通告符合路由验证规则, 则路由器可以将这个路由签名。邻居路由器通过在入口过滤器验证路由签名的有效性来确定该路由通告是否符合 BGP 路由通告规范。通过这个机制, TBGP 在每条路由路径中建立了一个可传递的信任关系。信任关系的核心依赖于前缀所有者用前缀的私钥对路由进行签名。每个 TBGP 路由器将在各自的入口过滤器中验证从邻居路由器中发送过来的路由通告中的签名。一个成功的签名验证意味着这个路由通告已经通过了邻居的验证而是真实的, 可被采纳和更新路由数据库 ADJ-RIB-IN 中的记录。如果 TBGP 进一步将其选为最佳路由路径, 则其同样会将新路径通告给邻居路由器。在发送通告前, TBGP 将根据路由验证规则检查该通告路由器的真实性, 并只会对验证成功的路由采用 AS 号对应的私钥进行签名操作。邻居路由器在收到新路由通告后, 就可以简单地通过验证签名来判断通告的真实性。

我们基于图1.6的例子来进一步解释 TBGP 的主要工作原理。假设 AS 1 通告其拥有的地址前缀 12.34.8.0/24, 为此路由器 R1 通告了一个指向该地址前缀的路由路径 {1}, 并且这个通告包含了该地址前缀的私钥签名。AS 2 中的路由器 R2 收到通告后, 如果签名可被成功验证, 则 R2 将使用这条通告更新其路由数据库 Adj-RIB-IN 中的路由记录。在 R2 将该通告中的新路径选为最佳路由后, 则 R2 会在出口过滤器进一步检测该路由是否符合路由验证规则。若通过, 则该路由真实存在。在该例子中, 待 R2 通告的路由路径为 {2, 1}, R2

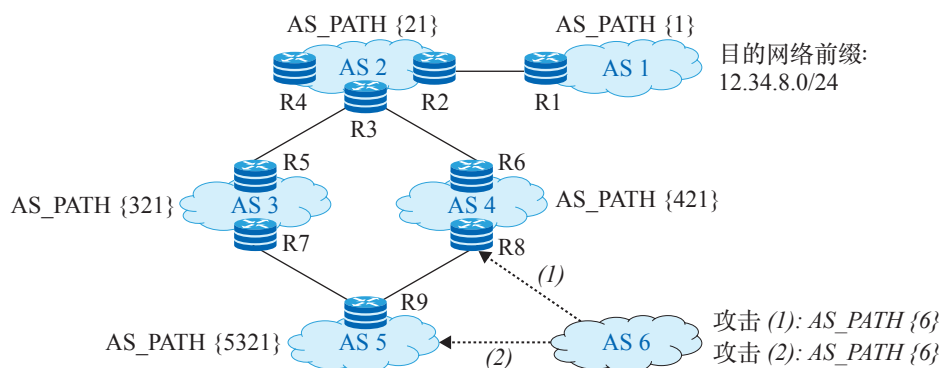


图 1.6 BGP 中正常路由和恶意路由通告的例子。(1) 表示了一个完全前缀劫持，(2) 表示了一个无效 AS 路径劫持

会使用 AS2 对应的私钥对其进行签名。同样，路由器 R3、R4 和 R5 将在入口过滤器中验证收到的路由并把携带正确签名的路由进一步通告给它们的邻居路由器。通过在邻居路由器之间传递信任关系，AS 1、AS 2、AS 3、AS 4 和 AS 5 均建立了对地址前缀 12.34.8.0/24 的信任关系。在此种场景下，由于无法获得该地址前缀的私钥签名，其他路由器（如 AS 6 中的路由器）无法进行前缀劫持攻击。类似地，伪造的路由路径（如 {6,1}）也会因为无法获得地址前缀的私钥签名而无法通过 AS 5 的验证，从而实现了对路径劫持攻击的防御。

3. 资源公钥基础设施

资源公钥基础设施 (Resource Public Key Infrastructure: RPKI) 是当前正在全球互联网推进部署的一种路由宣告认证架构，其核心思想是签发基于密码学的证书来证明每次互联网地址资源分配的真实性。通过检查新接收到的路由通告是否符合证书，就可以及时发现并丢弃用于发动前缀劫持攻击的虚假路由宣告。

从整体上看，RPKI 架构可划分为 3 部分：互联网地址分配体系、RPKI 资料库和依赖方 (Relying Party)。互联网地址分配体系是 RPKI 的基础，其负责分配地址资源并签发证书。如图 1.7 所示，互联网数字分配机构 (Internet Assigned Numbers Authority: IANA) 位于该体系的顶层，5 个区域互联网注册机构 (Regional Internet Registries: RIR) 位于其下，包括负责非洲地区地址资源分配的 AFRINIC，负责南极洲、加拿大、加勒比部分地区和美国地区

我国的国家互联网注册机构为中国互联网信息中心 (CNNIC)，其总部坐落于北京市中关村。

的 ARIN，负责东亚、大洋洲、南亚、东南亚地区的 APNIC，负责部分加勒比地区和拉丁美洲的 LACNIC，以及负责欧洲、中东、俄罗斯和中亚部分地区的 RIPE NCC。RIR 之下有国家互联网注册机构 (National Internet Registries: NIR) 和本地互联网注册机构 (Local Internet Registries: LIR)。互联网地址资源由 RIR 分配给各自管理的 NIR 和 LIR 后，再由它们进一步分配给最终的互联网服务供应商 (Internet Service Provider: ISP) 和终端用户。在该体系中，资源拥有者在将地址资源分配给申请者时，会签发证书来声明被分配的资源属于申请者。在将地址前缀分配给某个自治系统时，资源拥有者还会签发路由起源授权 (Route Origin Authorization: ROA)。RPKI 资料库是一个分布式的数据库系统，用于存储地址分配体系所签发的证书和 ROA。为了及时接收并更新数据，RPKI 资料库通常和相关的地址注册机构部署在一起。依赖方则是 RPKI 架构的使用者，负责从资料库接收证书和 ROA，验证并缓存其中记录的“前缀-源”关联信息。BGP 路由器可连接依赖方以获取这些可信的“前缀-源”关联信息，并用于验证其新接收路由宣告的真实性，进一步结合本地策略进行可能的路由宣告过滤。使用 RPKI 架构验证路由宣告中源 AS 真实性的过程也被称为路由源验证 (Route Origin Validation: ROV)。

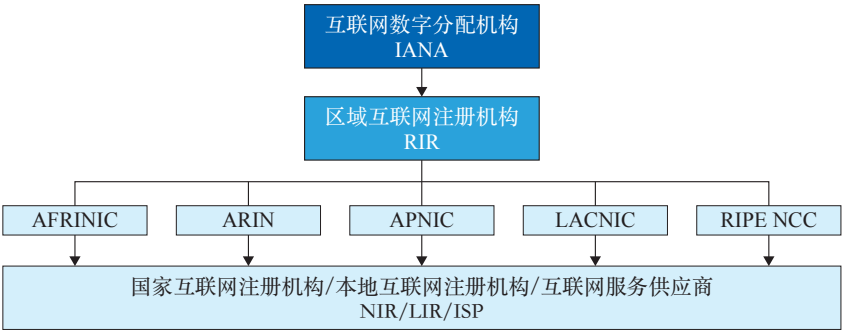


图 1.7 互联网地址分配体系

在 RPKI 架构中，路由起源授权 ROA 被用于声明一项或多项地址前缀资源已被授权给某个特定的自治系统，并由资源拥有者的证书签名进行保证。在 RPKI 系统中，共存在两类证书：CA 证书和 EE 证书。其中 CA 证书用于证明某个实体对象对特定地址资源的所有权，例如某段 IP 地址或 AS 号，并且 CA 证书是由资源拥有者用其自身私钥签名后再颁发给资源申请者。EE 证书则专门用于验证 ROA 的真实性，当地址前缀资源的拥有者将它们授权给特定自治系统时，会先使用该资源对应 CA 证书的私钥签发一个 EE 证书，再使用

EE 证书的私钥来签发对应的 ROA。证书和 ROA 都会被上传到 RPKI 的资料库中，以供依赖方验证 ROA 的真实性。因此，删除 EE 证书就可以删除相应的 ROA。

一个有效的 ROA 中通常包含一个自治系统 AS 号，一个地址前缀列表和这些地址前缀的最大匹配长度，其中地址前缀列表包含了授权给自治系统的前缀资源。一条路由宣告中的地址前缀如果与某条 ROA 中的地址前缀完全相同，或宣告地址前缀比某条 ROA 中的地址前缀更加具体，但宣告地址前缀的长度小于或等于 ROA 中的前缀最大匹配长度，则认为该路由宣告与 ROA 在地址前缀相匹配。依赖方在获取到有效的 ROA 记录并通过证书验证其真实性后，采用如下步骤判断一条路由宣告是否合法：（1）如果待验证路由宣告的地址前缀与任何 ROA 均不匹配，则返回“未知”结果；（2）对于存在地址前缀相匹配 ROA 的待验证路由宣告，如果其源 AS 与某条相匹配 ROA 中的 AS 号相同，则返回“合法”结果；（3）若不属于上述任一情况，则返回“非法”结果。路由器会将依赖方反馈的验证结果作为路由选择决策的一部分，例如优先采纳“合法”路由宣告所通告的新路由路径，而忽略“非法”路由宣告。

目前，ROA 的部署正稳步推进。根据 2023 年初域间路由安全组织 MANRS 的分析报告，当前已有 41.7% 的 IPv4 地址空间注册了 ROA，因而得到 RPKI 架构的保护。报告还估计，在 2023 年底互联网的 IPv4 地址空间将有超过 50% 得到 ROA 部署^[28]。然而，尽管 RPKI 在全球互联网不断推进，取得了卓有成效的前缀劫持防御效果，但其自身依然存在着一些不可忽视的安全问题与局限：

- **降级攻击威胁。**在 RPKI 架构下，AS 需通过依赖方正确获取各发布点中的签名对象（如 ROA）和相关证书（如 EE 证书），才能够进一步验证和使用 ROA 中记录的授权信息，以进行路由源验证。然而，依赖方从发布点获取数据的过程面临潜在的攻击威胁。比如，攻击者可以设法扰乱依赖方获取数据的过程，使得依赖方无法获取最新的 ROA 数据。在无法获取数据的情况下，依赖方缓存的 ROA 数据在一定时间后便会失效，进而导致使用该依赖方的 AS 无法再通过 RPKI 进行路由源验证。这类攻击，最终使受 RPKI 保护的域间路由降级为了不受保护的域间路由，因而被称为 RPKI 降级攻击。RPKI 降级攻击方式又包括低速率阻塞（Low rate blocking）和 Stalloris 攻击（Stalloris attack）^[29]。

低速率阻塞利用了 RPKI 发布点服务器的速率限制机制，攻击者可以伪造源 IP 地址为受害者（即依赖方）IP 地址的数据报文，并以爆发式的速

率发送至 RPKI 发布点服务器，从而触发发布点服务器的速率限制机制，使得所有来自受害者 IP 地址的真正的请求也被过滤。低速率阻塞的攻击时机需确保与依赖方发送查询请求的时间间隔同步，并执行多轮迭代直到依赖方的 ROA 缓存失效。实际的测量发现，有 47% 的发布点容易受到低速率阻塞的降级攻击，这也相当于互联网中 60% 的受 RPKI 保护的 IPv4 地址空间。

Stalloris 攻击的灵感来自于针对 TCP 连接的 Slowloris 拒绝服务攻击^[30]。在 Slowloris 拒绝服务攻击中，攻击者控制服务器，向受害者主机同时建立多个 HTTP 连接，并返回缓慢的响应，从而使受害者主机的正常访问受阻。类似地，在 Stalloris 攻击中，攻击者通过控制 RPKI 发布点服务器（攻击者可以自行搭建 RPKI），尽可能缓慢地响应来自依赖方的连接，从而使得依赖方获取数据的速度减慢甚至停滞，并影响依赖方继续访问其他的 RPKI 发布点。Stalloris 攻击的核心思想是，攻击者在其控制的 RPKI 发布点中建立一个很深的委托链（比如，反复将证书的下游委托给自己所控制的服务器），迫使依赖方反复访问由攻击者控制的发布点，从而拖延依赖方的正常工作。Stalloris 攻击可以和低速率阻塞相结合，减少低速率阻塞所需的攻击迭代次数（最少可降至 1 次），并形成隐蔽、高效的 RPKI 降级攻击。

针对 RPKI 降级攻击的防御措施包括：（1）在依赖方的实现中，限制其最大可访问的发布点证书的委托深度，以防止攻击者利用很深的委托链形成 Stalloris 攻击；（2）限制依赖方单次请求的最大时限，以防止攻击者通过发布点服务器的缓慢相应阻塞依赖方的工作；（3）在一定程度上随机化依赖方发送请求的时间间隔，以防止攻击者在确定的时间周期发动低速率阻塞攻击。

- **ROA 配置不当的隐患。**ROA 中记录了可信的路由源信息，包括前缀所授权宣告的 AS 号，以及所允许宣告的最长子前缀长度（max-length）。通过 RPKI 进行路由源验证的 AS，会使用 ROA 中的路由源信息指导其 BGP 路由器的过滤行为，过滤掉和 ROA 冲突的 BGP 宣告。然而，ROA 的配置在很大程度上受人为因素影响，因而会出现 ROA 误配置或者配置不当的情况，带来潜在的安全隐患。

ROA 误配置主要会造成互联网可达性受损。比如，某些粗心的运营商可能意外配置了错误的 max-length，导致其实际宣告的子前缀和 max-length

冲突；或者，在把子前缀分配给用户 AS 后，运营商忘记增添用户的 ROA 和更新已有的 ROA，导致用户 AS 的 BGP 宣告和 ROA 出现冲突。这类 ROA 误配置会造成部署路由源验证的 AS 错误地过滤正常的宣告，导致互联网可达性受损。2021 年的一项研究表明，当前 IPv4 中的 BGP 宣告有超过 7,000 个独立的前缀源信息和误配置的 ROA 存在冲突^[31]。如此规模的 ROA 误配置也成为了阻碍运营商部署 ROV 的重要因素之一。

此外，RPKI 的防御效果也可能因 ROA 配置不当而受损。比如，运营商可能因缺少安全意识，而随意地为某个/20 前缀的 ROA 配置了/24 的 max-length。在这种情况下，如果运营商实际宣告的前缀仍为/20（而非/24），虽然其正常宣告不受影响，但攻击者有机会发动针对更长子前缀（比如/24）的“1-hop”路径伪造攻击，进而逃避 RPKI 的防御。2017 年的一项研究表明，已注册 ROA 的前缀中，约有 1/3 的比例存在这种配置不当的情况^[32]。

解决 ROA 配置不当的问题，需要规范运营商签发 ROA 的最佳实践，减少 ROA 误配置的产生。同时，也可通过基于规则的方法，定期检查和过滤已存在的不当 ROA。

- **ROV 部分部署的隐患。**RPKI 的防御效果在很大程度上依赖其在互联网中的部署率。当前互联网中，ROA 的部署率正在稳步提高，目前已有 41.7% 的 IPv4 地址空间注册了 ROA^[28]。然而，2022 年的一项研究表明，当前互联网超过 70,000 个 AS 中，仅有约 3,000 个 AS 部署了 ROV^[33]。在可预见的一段时间内，互联网中的 ROV 仍将处于部分部署的状态，而 ROV 部分部署除了会显著降低 RPKI 的整体防御效果外，也会造成意想不到的安全隐患。比如，在 ROV 部分部署的情况下，已部署 ROV 的 AS 虽然能丢弃来自攻击者的路由，但其发往真实源 AS 的流量仍可能经过未部署 ROV 的 AS，如果某个未部署 ROV 的 AS 采纳了来自攻击者的路由，那么流量仍然会被劫持。这种现象被称为 ROV 部分部署带来的附加损害（collateral damage）^[32]。更为危险的是，在流量因 ROV 部分部署的附加损害而被劫持时，产生这些流量的 AS 可能根本就没有收到过攻击者发送的宣告，因此在其路由数据库中也根本看不到攻击者 AS 的可达性信息，导致劫持更为隐蔽，加大了检测难度。

针对 ROV 部分部署的安全隐患，一方面需要加快 RPKI 的部署速度，另一方面可以通过对互联网中多汇聚点路由信息的协同分析，发现可能存在

的因 ROV 部分部署而产生的附加损害，或通过数据面探针的主动探测，发现控制面难以发现的隐蔽劫持。

- **路径劫持防御缺失。**虽然 RPKI 可以验证路由宣告中源 AS 的真实性，有效防御前缀劫持攻击，但其对路径篡改类攻击无能为力。BGPsec 协议^[34]能够很好的解决这一问题，其不仅使用了 RPKI 架构来实现源 AS 验证，还在路由宣告中附加了签名来供接收方验证宣告中路由路径的真实性。在 BGPsec 协议中，一台路由器在转发路由宣告给其某个邻居路由器时，会对宣告中原有的签名和邻居路由器的 AS 号，使用该路由器自身的证书密钥来构造签名。如图1.8所示，AS 1 对地址前缀 p 、其自身的 AS 号和路由宣告需要发送的邻居 AS 2，使用其自身的证书私钥 $key1$ 来构造签名 $sig1$ 。AS 2 验证该路由宣告中的签名即可确认其真实性，再对 $sig1$ 和路由宣告需要转发的邻居 AS 3 使用其自身的证书私钥 $key2$ 来构造签名 $sig2$ 。AS 3 通过验证上述签名即可验证其接收到的路由路径 {AS2 AS1} 的真实性。然而，BGPsec 协议本身依然存在着一些需要解决的安全漏洞。相关研究表明，即使互联网完全部署了 BGPsec 协议，攻击者依然可以通过控制面的虫洞攻击 (Wormhole Attack) 来实现路由劫持^[35]，或采用路由操纵攻击 (Route Manipulation Attack) 来引发流量黑洞^[36]。在控制面上，攻击者可以发动摩尔攻击 (Mole Attack) 来造成流量转发回环，导致链路过载^[35]。此外，BGPsec 协议没有对控制面和数据面的一致性进行检查，攻击者同样可利用这一缺陷来实现路由操纵攻击^[37]。针对这些问题，可以从两方面增强 BGPsec 协议的安全性：(1) 拓展 BGPsec 协议，只为正在使用的地址前缀资源和链路生成证书，从而只允许包含真实物理链路的路由路径被宣告和采纳；(2) 在 BGP 路由器中构建可信执行环境，如 Intel SGX 和 AMD TrustZone，使得 BGP 路由器都可以验证邻居的路由和报文转发引擎，防止恶意路由通告行为。

1.2.5 前沿研究进展

在前文中，我们介绍了传统的虚假路由宣告检测机制和域间路由安全增强方案，但它们依然存在一定的缺点，如依赖正常路由的控制面配置信息或额外的数据面探测设备，在真实互联网中应用部署不够灵活高效。而现有域间路由协议安全增强方法同样存在着部署激励不足，降低路由器性能，乃至部分部署会导致信任链断裂并引入新安全风险的问题。为解决这些问题，近些年学术界

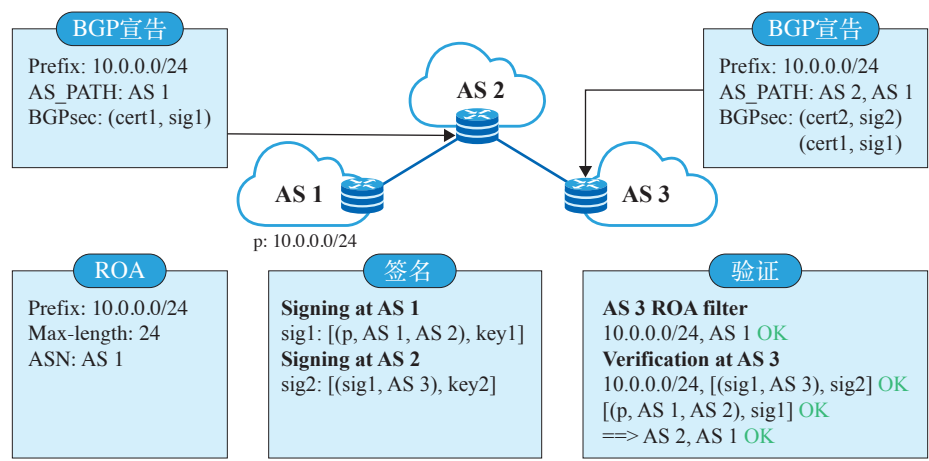


图 1.8 BGPsec 协议运行机制示例

和工业界提出了一系列新式域间路由安全技术。本节将介绍其中具有代表性的基于机器学习的域间路由异常和攻击检测技术，和一种新式基于可验证转发承诺的安全域间路由协议。

1. 基于机器学习的域间路由异常和攻击检测

基于机器学习的域间路由异常和攻击检测技术^[38-47]的核心思想是从历史路由数据中学习域间路由系统在异常状态或被攻击时的行为特征，再将这些特征应用于检测当前域间路由系统是否正常。具体来看，文献 [38, 40] 使用多尺度的 LSTM 神经网络模型和三十多个提取自 BGP 路由宣告的统计特征实现了对多种 BGP 异常状态的有效识别。针对长期发动劫持攻击的可疑自治系统，文献 [39] 使用 8 类共 52 种路由行为特征，包括全球路由表特定自治系统是否存在和单个地址前缀宣告的寿命，并构建了基于树的集成分类器来进行检测。文献 [41] 提出了一种基于自注意力机制改进的 LSTM 神经网络模型，其能够从行为特征和时间序列双维度细粒度建模正常与各类 BGP 异常事件，以实现更准确的检测性能。文献 [42] 发现 BGP 消息通常具有三类特性：确定性、递归性，和非线性。在此基础上，该文献提出了一种基于递归量化分析的 BGP 协议不稳定状态检测方法，能够帮助运维人员快速发现导致 BGP 协议不稳定的异常网络流量。文献 [43] 使用了多种特征选择算法筛选了与 BGP 异常最相关的特征，并基于支持向量机、隐马尔科夫模型、朴素贝叶斯等经典机器学习算法来构建了 BGP 异常检测模型。文献 [44] 使用一种增强后的决策树模型来发

现可见性异常的地址前缀资源，此类异常通常是互联网重大异常事件的早期症状。文献 [45] 针对路由误配置、节点失效和蠕虫攻击所导致的路由不稳定事件提出了一种在线检测方法，其从 BGP 更新消息中提取特征并分析时间和空间特征之间的关联性来识别异常，并且定位导致路由不稳定的根因自治系统。文献 [46] 基于每个自治系统的出现频率和地理差异特性，提出了一种完全无监督的路由劫持攻击检测方法。此外，文献 [47] 基于词嵌入思想，提出了一种可保留每个自治系统与其层次上下文关系的嵌入模型 BGP2VEC。在将自治系统嵌入表示为稠密向量的基础上，该文献方法通过循环神经网络实现了对路由劫持攻击的精准检测。

虽然机器学习方法检测域间路由异常和攻击的能力已得到验证，但需要在真实互联网的域间路由系统中部署应用此类技术依然需要克服一些挑战：（1）机器学习模型的检测能力通常依赖于高质量的训练数据，然而采集包括各类域间路由异常和攻击事件在内的大量训练数据不仅开销巨大，也往往因为攻击信息的缺失导致采集到的数据难以正确标注；（2）机器学习模型的判别结果会受到包括对训练样本在内的各种针对性攻击扰动，攻击者很可能通过这些方式构造特定的虚假路由宣告来操纵检测结果；（3）机器学习模型自身的黑盒特性导致判别结果缺乏可解释性，网络运维人员很难验证识别结果的正确性。

2. 基于可验证转发承诺的安全域间路由协议

基于可验证转发承诺的安全域间路由协议（Secure Inter-domain Routing and Forwarding via Verifiable Forwarding Commitments: FC-BGP）^[48] 是由清华大学提出的兼具灵活性和可部署性，能够对 BGP 路径宣告进行逐跳验证并实现隐私保护，同时能够实现跨平面验证的新式 BGP 路径验证方案。该方案克服了 RPKI 方案因部分部署导致信任链断裂而降低安全性，以及 BGPsec 无法保证流量是否按宣告路线正常转发的缺点。

FC-BGP 能够有效防御以下几类攻击者对 BGP 协议的攻击：（1）可以截获互联网范围内任意 BGP 宣告的攻击者；（2）可以在控制面篡改 BGP 宣告中携带的 AS_Path 属性的攻击者；（3）可以在数据面发送伪造源地址的数据包或篡改数据包的转发路径的攻击者。需要注意的是，FC-BGP 假定了不存在攻击者的合谋攻击（TIGER Attack）^[49]，即多个恶意 AS 通过隐秘信道（如隧道）建立 BGP 会话，从而伪造 AS 路径并逃避安全检测的一种复杂攻击方式。FC-BGP 的总体设计原理如图 1.9 所示，其关键设计概念是“转发承诺”（Forwarding Commitment: FC）。FC 是一个可公开验证的代码，用于证明 AS 对其直接连

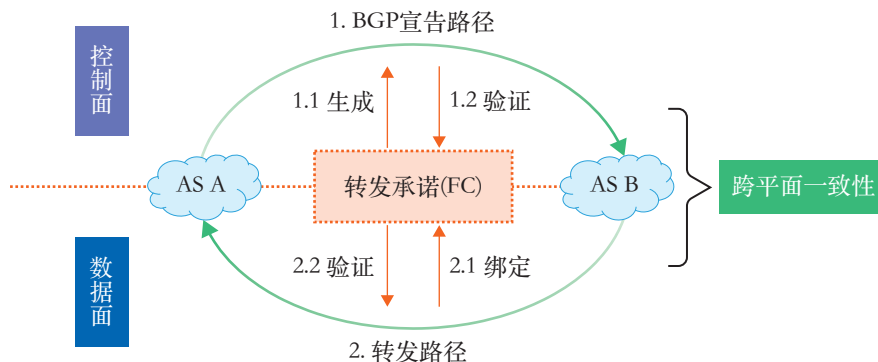


图 1.9 FC-BGP 协议的总体设计原理

接的某一跳的路由授权，即 FC 表明 AS 是否愿意通过该跳来承载特定网络地址前缀的流量。在接收到 BGP 更新通告后，如果 AS A 决定接受该通告中的路由并继续转发给其（选定的）邻居 AS B，则 AS A 会生成一个带有加密签名的 FC 来承诺其路由授权的真实性。之后，路径上下游的 AS，例如 AS B 就可以通过检查和各跳路由相关的 FC 来验证 BGP 更新通告的正确性。并且，由于 FC 是专门针对特定跳数和路径设计的，已经部署有 FC-BGP 的 AS 能够立即认证其路由授权，不需要依赖于其他 AS 的部署状态。与之相比，现有基于全路由路径验证的 BGP 安全协议（如 BGPsec 等）需要路由路径上的 AS 都已经支持该协议，否则路径上的 AS 无法验证任何形式的路由宣告。此外，由于 FC 是自证明的，AS 可以使用连续的每跳 FC 列表构建一个可认证的 AS 路径，然后将待发送流量（以 $\langle \text{src-AS}, \text{dst-AS}, \text{prefix} \rangle$ 标识）绑定到该路径上，例如 $\langle \text{AS B}, \text{AS A}, \text{P(B)} \rangle$ ，其中 P(B) 是 AS B 拥有的前缀。通过在全局范围内发布此类绑定信息，On-Path 和 Off-Path 的 AS 都能知道所需的转发路径，从而可以协同丢弃使用非授权路径的流量。FC 的这项功能特点能够进一步提高数据平面的转发验证效率。

基于 FC-BGP 组成的域间路由系统构成如图1.10所示。具体地，每个部署了 FC-BGP 路由器都将配属一个逻辑上的服务器，称为 FC Server。FC Server 和部署了 FC-BGP 的路由器（BGP speaker）之间通过安全 TCP 实现交互。当 BGP speaker 准备发出 UPDATE 消息时，FC Server 会负责生成其所携带的 FC，而当 BGP speaker 收到新的 UPDATE 消息时，FC Server 也负责验证其所携带 FC 的真实性，并将验证结果返回给 BGP speaker。此外，当 BGP speaker 完成控制面路由选择后，FC Server 之间会同步相关信息完成数据面路

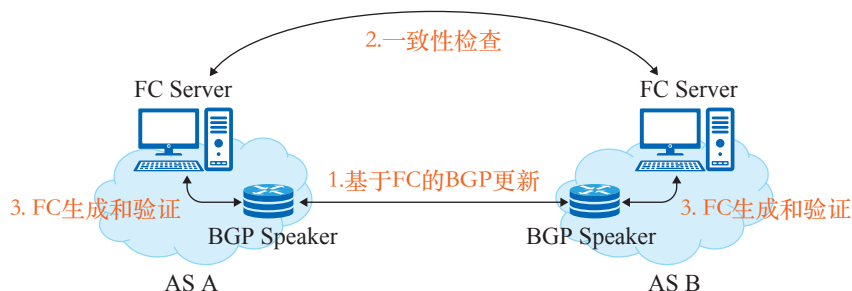


图 1.10 基于 FC-BGP 组成的域间路由系统示意

径绑定，从而保证绑定信息的一致性。

总结

本章围绕域内路由协议 OSPF 和域间路由协议 BGP 的攻击和防御介绍了路由安全领域的关键知识和研究进展。在章节 1.1 中，我们从 OSPF 协议本身存在的缺陷、OSPF 协议配置不当造成的问题和自适应域内路由本身固有的问题三个方面详细分析了现在 OSPF 协议面临的威胁，介绍了包括破坏正常路由转发功能和改变数据流经路由的两类针对 OSPF 协议的攻击。随后，我们介绍了一种 OSPF 安全防御方案。该方案从域内路由协议配置、域内路由协议完善和其他辅助增强机制三个方面来防御现有的 OSPF 协议攻击，提高了 OSPF 协议的安全性。在章节 1.2 中，我们先介绍了域间路由协议 BGP 面临的典型安全威胁：路由劫持和路由泄露，随后分别从检测虚假路由宣告和增强 BGP 协议安全性两个角度介绍了具有代表性的 BGP 协议安全防护方案。最后，我们介绍了域间路由安全领域的前沿研究进展和需要进一步解决的问题。

参考文献

- [1] Moy J. Rfc2328: Ospf version 2[M]. RFC Editor, 1998.
- [2] Coltun R, Ferguson D, Moy J. Rfc2740: Ospf for ipv6[M]. RFC Editor, 1999.
- [3] Repage K J, Jones E, Moigne O L. OSPF Security Vulnerabilities Analysis: draft-jones-ospf-vuln-01[R/OL]. Internet Engineering Task Force, 2003. <https://datatracker.ietf.org/doc/draft-jones-ospf-vuln/01/>.

- [4] Nakibly G, Sosnovich A, Menahem E, et al. Ospf vulnerability to persistent poisoning attacks: a systematic analysis[C]//Proceedings of the 30th Annual Computer Security Applications Conference. 2014: 336-345.
- [5] Moy J. Ospf version 2[R]. 1997.
- [6] Cohen R, Hess-Green R, Nakibly G. Small lies, lots of damage: a partition attack on link-state routing protocols[C]//2015 IEEE Conference on Communications and Network Security (CNS). IEEE, 2015: 397-405.
- [7] Nakibly G, Kirshon A, Gonikman D, et al. Persistent ospf attacks.[C]//NDSS. 2012.
- [8] 姚胜胜, 徐明伟. 服务功能链及其支撑网络可信路径研究[D]. Beijing, China: Tsinghua University, 2020.
- [9] Rekhter Y, Li T, Hares S. A border gateway protocol 4 (bgp-4)[R]. 2006.
- [10] Butler K, Farley T R, McDaniel P, et al. A survey of bgp security issues and solutions[J]. Proceedings of the IEEE, 2009, 98(1): 100-122.
- [11] Declan M. How pakistan knocked youtube offline (and how to make sure it never happens again)[EB/OL]. 2008. <https://www.cnet.com/culture/how-pakistan-knocked-youtube-offline-and-how-to-make-sure-it-never-happens-again/>.
- [12] Sriram K, Montgomery D, McPherson D, et al. Problem definition and classification of bgp route leaks[R]//RFC 7908. 2016.
- [13] Lad M, Massey D, Pei D, et al. Phas: A prefix hijack alert system.[C]//USENIX Security symposium: Vol. 1. 2006: 3.
- [14] Li J, Ehrenkranz T, Elliott P. Buddyguard: A buddy system for fast and reliable detection of ip prefix anomalies[C]//2012 20th IEEE International Conference on Network Protocols (ICNP). IEEE, 2012: 1-10.
- [15] Sermpezis P, Kotronis V, Gigis P, et al. Artemis: Neutralizing bgp hijacking within a minute[J]. IEEE/ACM Transactions on Networking, 2018, 26(6): 2471-2486.

- [16] Zhang Z, Zhang Y, Hu Y C, et al. ispy: Detecting ip prefix hijacking on my own[C]//Proceedings of the ACM SIGCOMM 2008 conference on Data Communication. 2008: 327-338.
- [17] Zheng C, Ji L, Pei D, et al. A light-weight distributed scheme for detecting ip prefix hijacks in real-time[J]. ACM SIGCOMM Computer Communication Review, 2007, 37(4): 277-288.
- [18] Shi X, Xiang Y, Wang Z, et al. Detecting prefix hijackings in the internet with argus[C]//Proceedings of the 2012 Internet Measurement Conference. 2012: 15-28.
- [19] Kent S, Lynn C, Seo K. Secure border gateway protocol (s-bgp)[J]. IEEE Journal on Selected areas in Communications, 2000, 18(4): 582-592.
- [20] Zhao M, Smith S W, Nicol D M. The performance impact of bgp security [J]. IEEE network, 2005, 19(6): 42-48.
- [21] Hu Y C, Perrig A, Sirbu M. Spv: Secure path vector routing for securing bgp[C]//Proceedings of the 2004 conference on Applications, technologies, architectures, and protocols for computer communications. 2004: 179-192.
- [22] White R. Securing bgp through secure origin bgp (sobgp)[J]. Business Communications Review, 2003, 33(5): 47-53.
- [23] Oorschot P v, Wan T, Kranakis E. On interdomain routing security and pretty secure bgp (psbgp)[J]. ACM Transactions on Information and System Security (TISSEC), 2007, 10(3): 11-es.
- [24] Shi E, Perrig A, Van Doorn L. Bind: A fine-grained attestation service for secure distributed systems[C]//2005 IEEE Symposium on Security and Privacy (S&P'05). IEEE, 2005: 154-168.
- [25] Butler K, McDaniel P, Aiello W. Optimizing bgp security by exploiting path stability[C]//Proceedings of the 13th ACM conference on Computer and communications security. 2006: 298-310.
- [26] Goldberg S, Halevi S, Jaggard A D, et al. Rationality and traffic attraction: Incentives for honest path announcements in bgp[C]//Proceedings

- of the ACM SIGCOMM 2008 conference on Data communication. 2008: 267-278.
- [27] Li Q, Xu M, Wu J, et al. Enhancing the trust of internet routing with lightweight route attestation[J]. IEEE Transactions on Information Forensics and Security, 2011, 7(2): 691-703.
- [28] Siddiqui A. Will 2023 be the year half of the internet is rpki-enabled? [EB/OL]. 2023 [Online]. <https://www.manrs.org/2023/01/will-2023-be-the-year-half-of-the-internet-is-rpki-enabled/>.
- [29] Hlavacek T, Jeitner P, Mirdita D, et al. Stalloris: RPKI downgrade attack[C/OL]//31st USENIX Security Symposium (USENIX Security 22). Boston, MA: USENIX Association, 2022: 4455-4471. <https://www.usenix.org/conference/usenixsecurity22/presentation/hlavacek>.
- [30] Cambiaso E, Papaleo G, Chiola G, et al. Slow dos attacks: definition and categorisation[J/OL]. International Journal of Trust Management in Computing and Communications, 2013, 1(3-4): 300-319. DOI: 10.1504/IJTMCC.2013.056440.
- [31] Hlavacek T, Shulman H, Waidner M. Smart rpki validation: Avoiding errors and preventing hijacks[C]//European Symposium on Research in Computer Security. Springer, 2022: 509-530.
- [32] Gilad Y, Cohen A, Herzberg A, et al. Are we there yet? on rpki's deployment and security[J]. Cryptology ePrint Archive, 2016.
- [33] Chen W, Wang Z, Han D, et al. Rov-mi: Large-scale, accurate and efficient measurement of rov deployment[C]//Network and Distributed System Security Symposium. 2022.
- [34] Lepinski M, Sriram K. Bgpsec protocol specification[R]//RFC 8205. 2017.
- [35] Li Q, Hu Y C, Zhang X. Even rockets cannot make pigs fly sustainably: Can bgp be secured with bgpsec[C]//Workshop SENT' 14, 23 February 2014, San Diego, USA, Copyright 2014 Internet Society: Proceedings. Internet Society, 2014.

- [36] Song Y, Venkataramani A, Gao L. Identifying and addressing reachability and policy attacks in “secure” bgp[J]. IEEE/ACM Transactions on Networking, 2016, 24(5): 2969-2982.
- [37] Goldberg S, Schapira M, Hummon P, et al. How secure are secure interdomain routing protocols[J]. ACM SIGCOMM Computer Communication Review, 2010, 40(4): 87-98.
- [38] Cheng M, Xu Q, Jianming L, et al. Ms-lstm: A multi-scale lstm model for bgp anomaly detection[C]//ICNP. IEEE, 2016: 1-6.
- [39] Testart C, Richter P, King A, et al. Profiling bgp serial hijackers: capturing persistent misbehavior in the global routing table[C]//IMC. 2019: 420-434.
- [40] Cheng M, Li Q, Lv J, et al. Multi-scale lstm model for bgp anomaly classification[J]. TSC, 2018.
- [41] Dong Y, Li Q, Sinnott R O, et al. Isp self-operated bgp anomaly detection based on weakly supervised learning[C]//ICNP. IEEE, 2021: 1-11.
- [42] Al-Musawi B, Branch P, Armitage G. Detecting bgp instability using recurrence quantification analysis (rqa)[C]//IPCCC. IEEE, 2015: 1-8.
- [43] Al-Rousan N M, Trajković L. Machine learning models for classification of bgp anomalies[C]//HPSR. IEEE, 2012: 103-108.
- [44] Lutu A, Bagnulo M, Cid-Sueiro J, et al. Separating wheat from chaff: Winnowing unintended prefixes using machine learning[C]//INFOCOM. IEEE, 2014: 943-951.
- [45] Deshpande S, Thottan M, Ho T K, et al. An online mechanism for bgp instability detection and analysis[J]. TOC, 2009, 58(11): 1470-1484.
- [46] Theodoridis G, Tsigkas O, Tzovaras D. A novel unsupervised method for securing bgp against routing hijacks[M]//ISCIS. Springer, 2013: 21-29.
- [47] Shapira T, Shavitt Y. A deep learning approach for ip hijack detection based on asn embedding[C]//NetAI. 2020: 35-41.

- [48] Xu K, Wang X, Liu Z, et al. Framework of forwarding commitment bgp [EB/OL]. 2023. <https://www.ietf.org/id/draft-wang-sidrops-fcbgp-framework-00.html>.
- [49] Li Q, Zhang X, Zhang X, et al. Invalidating idealized bgp security proposals and countermeasures[J]. IEEE Transactions on Dependable and Secure Computing, 2014, 12(3): 298-311.

习题

1. 域间路由和域内路由的关系是怎样的？请简述互联网是如何在当前的路由系统下运作的
2. OSPF 在协议设计上存在哪些安全漏洞？请分类简述。
3. OSPF 的实现和配置可能存在哪些安全漏洞？请分类简述。
4. 针对 OSPF 的攻击有哪些？请分类简述。
5. 请调研一种针对 OSPF 的安全防御方案，并简述其设计思路。
6. 请调研一起 BGP 安全事件（如 2008 年巴基斯坦电信劫持 YouTube），并简述事件过程。
7. 请访问一个常用网站，并通过工具（如 traceroute）分析访问的流量经过了哪些 AS，这些 AS 属于哪些组织，以及它们之间的商业关系。
8. 请分析和简述路由劫持和路由泄露的区别与共性。
9. 检测虚假 BGP 宣告可以采用哪些技术路线？请分类简述
10. 将机器学习技术应用于路由安全任务需要克服哪些挑战？